LABORATUVAR 5 · PAKETPRO 3000 · Paketleme Makinesi

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	PaketPro Component X (PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Üç şart: (1) Bileşen var mı: VMGS 2504 SBOM'unda (özellikle NC arka dayama opsiyonunda) Component X var mı; standart elektromekanik makinede büyük olasılıkla yok. (2) Sürüm 2.4 etkileniyor mu? (3) Açık ulaşılabilir mi (ağ/uzak modül)? Üçü de evet değilse CVE bizi etkilemez.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hayır, hemen durdurmam. Önce üç şart doğrulanır; açık ağdan ulaşılamıyorsa risk düşüktür. Ulaşılabiliyorsa önce uzak erişimi keserim (geçici önlem), yamayı planlı bakım penceresinde uygularım; bıçak enerjisizken çalışılır.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: yama üretim makinesine değil test/yedek NC kontrolörde ya da bakım penceresinde, bıçak bölgesi boş ve enerji kontrollü şekilde denenir; yedek alınır, geri dönüş planı hazırlanır; sonuç iyi ise sahaya uygulanır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Evet, etkileyebilir: yama emniyet fonksiyonuna (kafes kilidi, e-stop, kavrama durdurma) dokunuyorsa validasyon tekrarlanır. Anlamak için değişiklik notu/etki analizi okunur; yama sonrası fonksiyon testi yapılır (kafes açık → kesme başlamaz, e-stop → bıçak durur, durma süresi ölçülür).

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Telafi edici önlem: uzak erişimi kapatmak veya ağdan izole etmek, güvenlik duvarı kuralı, VPN + MFA, USB portlarını kilitlemek, izleme/log, bağımsız donanımsal emniyet rölesi; yama gelene kadar uzak bakım modülünü fiziksel olarak sökmek.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.